

The Arzens

Governance, Risk & Compliance (GRC) Internship Project

Phase 4

ISO/IEC 27001:2022
Internal Audit Simulation

Audit Nonconformity Report



Usama Arshad

Governance, Risk & Compliance
(GRC) Internship

Lead: Shahal Farid

Co-Lead: Anas Zeeshan



Fictional Organization:
Kohsar Digital Bank (KDB)

Submission Date:
Monday, August 24, 2026

1. Purpose and Scope of This Document

This report documents the confirmed nonconformities identified during the control assessment and evidence collection phase of the ISO/IEC 27001:2022 Internal Audit Simulation for Kohsar Digital Bank (KDB). Each nonconformity in this report is based on objective, traceable evidence against an established audit criterion—either an ISO/IEC 27001:2022 requirement, an Annex A control referenced in KDB’s Statement of Applicability (SoA), or a specific requirement in one of KDB’s own governing policies.

This report covers confirmed nonconformities only. Items for which the available evidence was insufficient to reach a defensible conclusion, or where KDB source documents conflict without an established basis for reconciliation, are not included here as nonconformities. Instead, they are recorded separately as open items requiring KDB governance action, since concluding a nonconformity against an undefined or conflicting criterion would not be supported by the evidence.

Corrective action recommendations for the nonconformities documented in this report are addressed in the separate Phase 4 Corrective Action Recommendations deliverable.

2. Severity Methodology

Severity classifications in this report follow the methodology established during the audit:

- **Major** — absence or significant breakdown of a required ISMS/process, a widespread or systemic failure, or a failure materially affecting KDB’s ability to achieve intended information security outcomes.
- **Minor** — an isolated or limited failure against an established requirement, where the relevant process or control exists and is generally implemented, but a specific instance does not conform.

All six confirmed nonconformities documented in this report are classified as Minor. No Major nonconformity was identified during this audit.

3. Summary of Confirmed Nonconformities

NC ID	Reference	Nonconformity Summary	Severity
NC-01	Governance & Risk Escalation Flow — Stage 3 SLA	2 of 8 sampled escalations breached the 3-business-day Stage 3 SLA with no documented exception.	Minor
NC-02	A.5.9 — Inventory of information and other associated assets	2 asset records lacked required classification information.	Minor
NC-03	A.5.15 — Access control	2 de-provisioning tickets breached the 24-hour revocation requirement by 5 and 7 days, with no documented exceptions.	Minor
NC-04	A.6.1 — Screening	Background verification records were missing for 2 of 10 sampled new hires.	Minor
NC-05	A.6.8 — Information security event reporting	1 Medium-severity event breached the 24-hour escalation requirement by 6 hours, with no exception filed.	Minor
NC-06	A.8.24 — Use of cryptography	The required cryptographic/key-management standard document is confirmed absent, though the encryption control itself is evidenced as operating.	Minor

4. Detailed Nonconformities

NC-01 – Governance & Risk Escalation Flow, Stage 3 SLA

Reference: Governance & Risk Escalation Flow (internal KDB governance criterion)

Applicable Criterion: Governance & Risk Escalation Flow — Stage 3 (GRC Co-Lead Review), 3-business-day SLA

Statement of Nonconformity: We sampled eight escalation-log entries from KDB's Q2 2026 escalation records. Of these, six met the Stage 3 SLA, while two exceeded the SLA by 2 and 4 days, respectively, with no documented exceptions for either delay.

Objective Evidence: EL-03 — Governance & Risk Escalation Flow and escalation records were reviewed against the five defined escalation stages and their SLAs.

Severity Rationale: The escalation process and Stage 3 review function operate correctly in the majority of the sample (6 out of 8). The two breaches are isolated incidents against an established SLA, indicating that the escalation process is neither absent nor systemically broken, which supports a Minor classification.

NC-02 – A.5.9, Inventory of Information and other Associated Assets

Reference: A.5.9

Applicable Criterion: SoA evidence expectation: asset register/CMDB export showing owner, classification, and location fields populated for all in-scope assets.

Statement of Nonconformity: Among the sampled asset records, two non-current assets lacked the required classification information.

Objective Evidence: EL-08 — Asset register/inventory reviewed; the classification field was found blank on two sampled records.

Severity Rationale: The asset inventory process exists, and the identified classification gap is limited to two records. The evidence does not suggest that the classification process is absent or systemically broken, supporting a Minor classification.

NC-03 – A.5.15, Access Control

Reference: A.5.15 (primary finding; cross-referenced by A.6.5)

Applicable Criterion: Task 9 KDB Access Control Policy §3.2 — access revocation within 24 hours of HR-confirmed termination notification (4 hours for Restricted-tier systems), with missed timeframes documented as a policy exception.

Statement of Nonconformity: Out of 15 sampled de-provisioning tickets, two—both associated with a single May 2026 system migration window—were completed 5 and 7 days after the HR-confirmed termination notification, breaching the 24-hour requirement. Neither breach was documented as a policy exception as required by §3.2.

Objective Evidence: EL-10 — Access control records and de-provisioning tickets were sampled and reviewed against the Task 9 §3.2 revocation requirement.

Severity Rationale: Provisioning was fully conformant across the sample (15 out of 15), and the two de-provisioning breaches are isolated to a single migration event rather than indicating that the access control process is absent or systemically broken, which supports a Minor classification. This is the primary finding for these two events; the same evidence is pertinent to A.6.5 (responsibilities after termination) but is cross-referenced here rather than counted as a second, independent nonconformity.

NC-04 – A.6.1, Screening

Reference: A.6.1

Applicable Criterion: SoA evidence expectation: background verification records or third-party screening vendor confirmations on file for all new hires in scope.

Statement of Nonconformity: Of 10 sampled new hires with access to in-scope systems, background verification records were available for 8; no record was found for 2.

Objective Evidence: EL-14 — Background verification records reviewed against a sample of 10 new hires.

Severity Rationale: The screening record-keeping process exists and is followed for the large majority of the sample (8 of 10). The gap is limited to 2 identified records, not evidence the screening process itself is absent — supporting a Minor classification. No screening-timing requirement is established in any KDB source and none was applied in reaching this conclusion.

NC-05 – A.6.8, Information Security Event Reporting

Reference: A.6.8

Applicable Criterion: Task 9 KDB Incident Reporting Policy §3.1 (reporting via designated channel) and §3.2 (severity-based escalation timeframes: Critical 1 hour, High 4 hours, Medium 24 hours).

Statement of Nonconformity: Of 12 sampled reported events, all 12 were reported through the designated channel and triaged. 1 Medium-severity event was escalated 30 hours after detection, exceeding the 24-hour requirement by 6 hours, with no documented exception.

Objective Evidence: EL-17 — Incident reporting log and escalation records, sampled and reviewed against the Task 9 §3.2 timeframes.

Severity Rationale: The reporting channel and triage function are demonstrated across the full sample; the single escalation-timeframe breach is an isolated instance, and the sample does not reach Task 9's own separate 2-instance/90-day threshold for CISO/GRC Lead review. That threshold concerns escalation and review and does not negate the individual 24-hour escalation requirement, which was breached once. The isolated breach supports a Minor classification.

NC-06 – A.8.24, Use of Cryptography

Reference: A.8.24

Applicable Criterion: rules for the effective use of cryptography, including cryptographic key management, are defined and implemented; KDB's SoA identifies a cryptographic/key-management standard document as an expected evidence artifact.

Statement of Nonconformity: No cryptographic/key-management standard or equivalent documented rules were identified in KDB's available artifact set to demonstrate that the requirements for the effective use of cryptography and cryptographic key management have been formally defined.

Objective Evidence: EL-25 — Cryptographic/key-management standard review, TLS certificate inventory, and cloud encryption configuration evidence.

Severity Rationale: The underlying encryption control is evidenced and operating for the systems tested (TLS across all 8 sampled endpoints; cloud encryption-at-rest enabled). The absence of the required governance document, without evidence that the control itself is failing, constitutes an isolated gap against an established evidence requirement rather than a systemic or absent control — supporting a Minor classification. On-premises database encryption-at-rest status is unevidenced and is retained strictly as an evidence limitation; it is not treated as evidence that encryption is absent, and does not form part of this finding.

5. Items Not Included in This Report

The following items are not classified as nonconformities in this report, consistent with the audit's evidence-first methodology. They remain recorded as open items requiring KDB governance, documentation, or further evidence action:

- **Clause 6.1.3 (Information security risk treatment)** — Pending; no objective evidence of the upstream risk assessment/treatment process was available.
- **Clause 7.5 (Documented information)** — Pending; a genuine conflict exists between KDB's actual policy-approval practice (Task 9's five policies, uniformly approved by "CISO") and the Governance Charter/Policy Hierarchy's defined approval tiers, which do not define a CISO role.
- **A.5.19 (Supplier relationships)** — Pending; supplier risk-tier classifications were not established, and the applicable KDB policy ties the annual review requirement to high-risk suppliers specifically.
- **A.6.3 (Awareness training)** — Pending; no KDB source establishes a required training completion threshold or cadence.
- **A.6.5 (Responsibilities after termination), HR-notification leg** — Pending; no KDB source establishes a deadline for HR to issue the termination notification that starts the 24-hour revocation clock.
- **A.7.7 (Clear desk and clear screen)** — Pending; no KDB source defines the required audit frequency.
- **A.8.8 (Vulnerability management), A.8.9 (Configuration management), A.8.13 (Backup)** — Pending; no KDB source establishes the applicable remediation timeframe, coverage threshold, or restore-test frequency, respectively.

Clause 8.1 (Operational planning and control) is separately concluded as conforming, with documented evidence limitations, based on the aggregate assessment of the 19 applicable Annex A controls. It is not classified as a nonconformity.

6. Conclusion

Six confirmed nonconformities were identified during the audit, all classified as Minor. No Major nonconformity was identified. The remaining Pending items and any documented evidence or source-mapping limitations are recorded separately and are not converted into nonconformities in this report.

- End of Report -